became the norm. When auditors finally arrived to assess compliance, no one could provide a clear answer to a simple question: who has access to what, and why?

ACME Corp's journey is far from unique. Most organizations begin with basic access controls and scale their way into complexity. The good news? Established models exist that provide structure, repeatability, and control—models that can tame the sprawl and support the growth of any digital system.

> ***NOTE***
>
> In practice, most organizations don't rely on a single access control model; they often use a mix, sometimes by design, sometimes by necessity. Access rules may be based on roles in one system, attributes in another, and relationships in yet another. Some decisions are enforced by centralized policy engines, while others are hardcoded for historical reasons or dictated by the constraints of SaaS applications. Understanding these models isn't about picking the "right" one, but rather knowing how to work across all of them.

We categorize these models as either static or dynamic, based on how they evaluate authorization decisions. Static models rely on predefined rules tied to identities or roles. They are easy to understand and efficient to evaluate, but they don't account for changing conditions, relationships, or context at runtime. Dynamic models, on the other hand, incorporate attributes, context, and policies that can adapt to the moment, making them more flexible but also more complex.

This chapter discusses two foundational static authorization models: Access Control Lists (ACLs) and Role-Based Access Control (RBAC). These models are deeply embedded in the infrastructure of modern systems and continue to play a critical role in many real-world environments. The next chapter will explore dynamic authorization models that evaluate access based on context, environmental conditions, and entity relationships.